MAGERIT

& PILAR Basic

Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información

Herramienta oficial del CCN-CERT para evaluación de riesgos TI

Centro Criptológico Nacional | Versión 3 | España

¿Qué es MAGERIT?

Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información

Origen

Desarrollada por el Consejo Superior de Administración Electrónica de España. Publicada por el Ministerio de Administraciones Públicas. Versión actual: MAGERIT v3 (2012).

Propósito

Sistematizar el análisis de riesgos TI en la Administración Pública española, cumpliendo con el Esquema Nacional de Seguridad (ENS).

Alcance

Obligatoria en el sector público español. Ampliamente adoptada en empresas privadas, infraestructuras críticas y entornos regulados.

MAGERIT es el estándar de referencia para la gestión de riesgos en la Administración española, alineado con ISO 27005 y ENS.

Estructura de MAGERIT v3

Libro I
El Método

- Marco conceptual de activos, amenazas y riesgos
- Proceso de análisis y gestión de riesgos
- Identificación y valoración de activos
- Definición de salvaguardas y tratamiento del riesgo
- Documentación del proceso completo

Libro II
Catálogo de Elementos

- Tipos de activos (datos, servicios, software, HW...)
- Dimensiones de seguridad (D, I, C, A, T)
- Catálogo de amenazas tipificadas
- Catálogo de salvaguardas recomendadas
- Base de conocimiento reutilizable

Libro III
Guía de Técnicas

- Técnicas de análisis (árboles de ataque, etc.)
- Análisis mediante tablas
- Algoritmos de evaluación cuantitativa
- Técnicas de evaluación de impacto
- Mapas de riesgo y matrices de decisión

Proceso de Análisis de Riesgos MAGERIT

6 fases estructuradas para una gestión completa del riesgo

01

Identificación de Activos

Inventariar todos los activos TI y su valor para la organización

02

Valoración de Activos

Estimar el valor en dimensiones D/I/C/A/T según impacto

03

Análisis de Amenazas

Identificar amenazas relevantes y su probabilidad

04

Estimación del Impacto

Calcular el daño potencial si se materializa la amenaza

05

Estimación del Riesgo

Combinar impacto × probabilidad para obtener el nivel de riesgo

06

Tratamiento del Riesgo

Decidir salvaguardas: aceptar, mitigar, transferir o eliminar

Activos y Dimensiones de Seguridad

Tipos de Activos

- Datos / Información
- Servicios
- Software / Aplicaciones
- Hardware / Equipos
- Comunicaciones / Redes
- Instalaciones físicas
- Personal

Dimensiones de Seguridad (DICAT)

D — Disponibilidad
El servicio/dato está accesible cuando se necesita

I — Integridad
Los datos no han sido alterados de forma no autorizada

C — Confidencialidad
Solo los autorizados acceden a la información

A — Autenticidad
La identidad de origen puede verificarse

T — Trazabilidad
Las acciones pueden rastrearse y atribuirse

PILAR Basic — La Herramienta

PILAR (Procedimiento Informático-Lógico para el Análisis de Riesgos) es la herramienta oficial del CCN-CERT que implementa la metodología MAGERIT. La versión Basic está disponible de forma gratuita para la Administración Pública española y es utilizada por más de 1.000 organismos.

Gratuita

PILAR Basic es de uso gratuito para la Administración Pública española y de bajo coste para privados.

Implementa MAGERIT

Automatiza todas las fases del proceso MAGERIT v3 con el catálogo oficial de amenazas y salvaguardas.

Informes y Mapas

Genera automáticamente mapas de riesgo, informes de cumplimiento ENS y reportes ejecutivos.

Alineada con ENS

Contiene perfiles de cumplimiento con el Esquema Nacional de Seguridad (RD 311/2022).

Proyectos Reutilizables

Permite crear plantillas y reutilizar proyectos base para organizaciones similares.

Integración

Se conecta con otras herramientas del CCN-CERT: LUCIA, CARMEN, GLORIA.

Flujo de Trabajo en PILAR Basic

Paso a paso desde la creación del proyecto hasta el informe final

1 Nuevo Proyecto

Crear proyecto, definir organización, sistema de información y sus fronteras.

2 Inventario de Activos

Introducir activos mediante el catálogo: datos, servicios, HW, SW, RRHH...

3 Valorar Activos

Asignar valores 0–10 en cada dimensión (D, I, C, A, T) por activo.

4 Analizar Amenazas

Seleccionar amenazas aplicables del catálogo y ajustar frecuencia y degradación.

5 Evaluar Salvaguardas

Indicar las salvaguardas implantadas y su nivel de madurez (0–100%).

6 Generar Informes

Exportar mapas de riesgo residual, cumplimiento ENS e informes ejecutivos.

Ejemplo Práctico: Ayuntamiento

Caso: Sistema de Gestión Tributaria de un Municipio

Activo	Tipo	Disponib.	Integrid.	Confidenc.	Riesgo Inicial
BBDD Padrones	Datos	9	9	9	CRÍTICO
Portal Tributario	Servicio	8	7	8	ALTO
Servidor Web	HW	7	6	6	MEDIO-ALTO
Red interna	Comunicac.	8	5	5	MEDIO
PC Técnicos	HW	6	5	7	MEDIO

Amenazas identificadas sobre BBDD de Padrones:

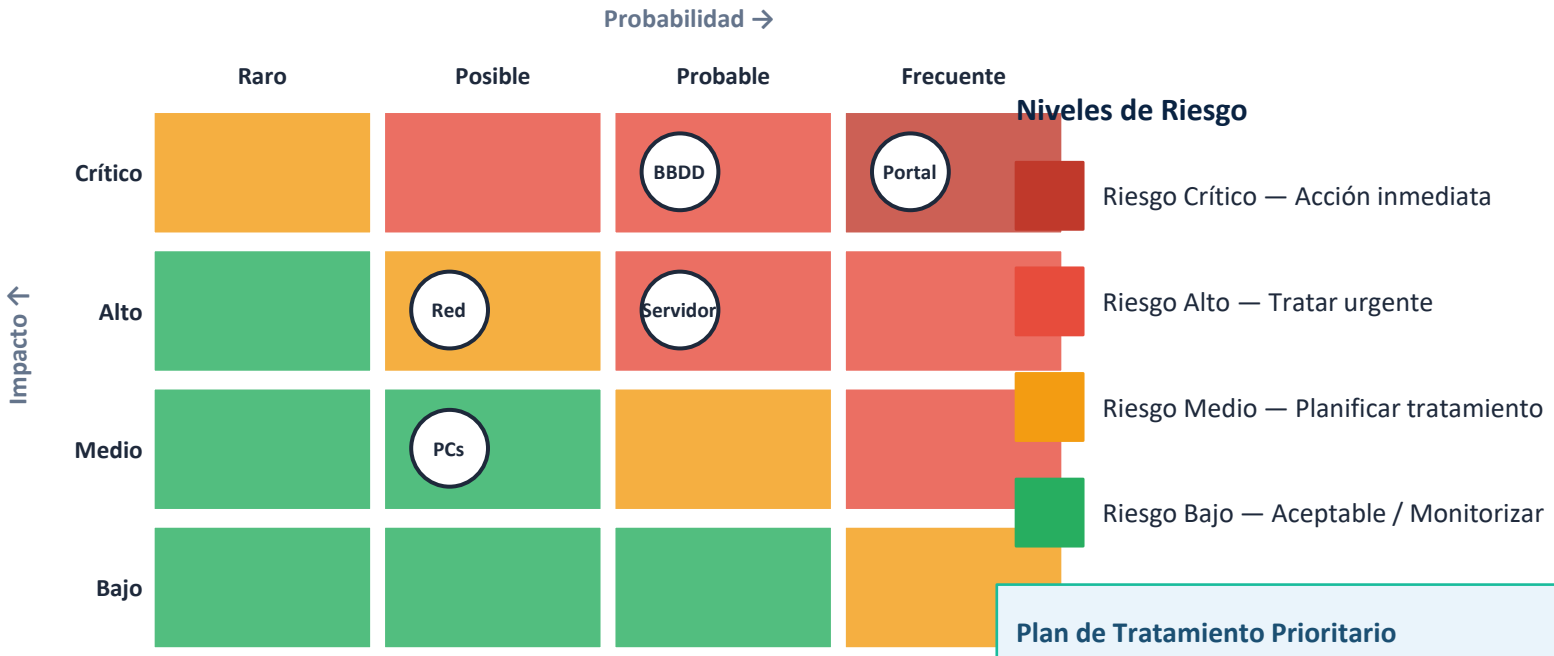
E.1 Errores de los usuarios	Frecuente	Medio	ALTO	*Copias de seguridad diarias, control de acceso por roles*
A.11 Acceso no autorizado	Posible	Alto	CRÍTICO	*Autenticación MFA, cifrado BD, auditoría de accesos*
N.1 Fuego / Desastre	Raro	Muy Alto	MEDIO	*CPD redundante, backup offsite, plan de continuidad*

Comparativa con Otras Metodologías

Criterio	MAGERIT	ISO 27005	OCTAVE	NIST SP 800-30	CRAMM
Origen	España (CCN)	ISO/IEC	CERT/CC EE.UU.	NIST EE.UU.	UK/Siemens
Enfoque	Cuantitativo	Marco general	Cualitativo	Cuantitativo	Cuantitativo
Obligatorio en	Admin. Pública ES	Sector privado	EE.UU. / Global	Fed. EE.UU.	UK Gov.
Herramienta	PILAR	Múltiples	Worksheets	Múltiples	CRAMM Tool
Curva aprend.	Media	Alta	Media-baja	Media	Alta
Catálogo amenaz.	Sí (oficial)	No incluye	Parcial	Sí	Sí
Integrac. ENS	✅ Nativa	Parcial	❌ No	❌ No	❌ No
Coste herram.	Gratuito (Basic)	Variable	Gratuito	Gratuito	Comercial

✅ **MAGERIT destaca por su integración nativa con el ENS, su herramienta oficial gratuita (PILAR) y su catálogo español de amenazas.**

Mapa de Riesgo — Resultado en PILAR



Plan de Tratamiento Prioritario

- ✓ 1. Implantar MFA en portal tributario
- ✓ 2. Cifrar BBDD de padrones (AES-256)
- ✓ 3. Segmentar red y VLAN crítica
- ✓ 4. Backup diario offsite para BBDD

¿Por Qué MAGERIT?

Razones clave para adoptar esta metodología en tu organización

Obligación Legal

Todas las AAPP en España están obligadas a cumplir el ENS. MAGERIT es el método de referencia y PILAR la herramienta oficial para demostrar cumplimiento en auditorías.

Reconocimiento Internacional

Alineada con ISO/IEC 27005 e ISO 31000. Permite certificaciones internacionales sobre una base metodológica rigurosa ya implantada.

Catálogo Completo

El catálogo oficial de amenazas y salvaguardas en español elimina la ambigüedad y reduce el tiempo de análisis frente a otros marcos genéricos.

Bajo Coste de Adopción

La herramienta PILAR Basic es gratuita. La metodología está documentada y publicada libremente por el MPTFP. Alta comunidad de práctica en España.

Proceso Iterativo

MAGERIT permite análisis incrementales y revisiones periódicas del riesgo, adaptándose a los cambios tecnológicos y organizativos de la entidad.

Apoyo del CCN-CERT

El Centro Criptológico Nacional ofrece soporte, formación, guías (Series CCN-STIC) y actualizaciones continuas de la herramienta PILAR.

Conclusiones

1. MAGERIT es el estándar de gestión de riesgos TI más relevante para la Administración española.
2. PILAR Basic permite aplicar toda la metodología de forma gratuita, estructurada y auditable.
3. La combinación MAGERIT + PILAR garantiza cumplimiento con el ENS y facilita certificaciones ISO.
4. Su proceso iterativo de 6 fases proporciona una visión continua y actualizada del riesgo residual.
5. Frente a otras metodologías, destaca por su catálogo oficial, herramienta gratuita y soporte CCN-CERT.